

Simulace útoků na hesla

BPC-AKR

Zdeněk Ondra, Lukáš Makovička, Jiří Pokluda

1. Obsah

2.	ÚVOD	3
3.	CÍLE PROJEKTU	4
4.	TEORETICKÁ ČÁST	5
4.1.	Bezpečné ukládání hesel	5
4.2.	Hashovací funkce	5
4.3.	Solení hesel	5
4.4.	Metody útoků na hesla	5
4.5.	Složitost hesel a entropie	6
4.6.	Rizika a jejich mitigace	6
4.7.	Shrnutí	6
5.	AKTUÁLNÍ STAV A NÁVRH DALŠÍHO POSTUPU	7
5.1.	Aktuální stav projektu	7
5.2.	Návrh dalšího postupu	7
5.2.1	Modul pro hashování	7
5.2.2.	Slovníkový útok	7
5.2.3.	Útok hrubou silou	7
5.2.4.	Útok pomocí rainbow tables	8
5.2.5.	Testovací databáze hashů	8
5.3.	Plán měření a vyhodnocení	8
5.3.1.	Měřené metriky	8
5.3.2.	Testovací data	8
5.3.3.	Metodika vyhodnocení	9
5.3.4.	Interpretace výsledků	9
6.	PŘEDSTAVENÍ AUTORŮ	10
7.	ZÁVĚR	11
8.	LITERATURA	12

2. Úvod

Projekt se zaměřuje na analýzu bezpečnosti uživatelských hesel prostřednictvím simulace různých typů útoků. V současnosti patří hesla stále mezi nejpoužívanější autentizační mechanismy, je proto důležité porozumět jejich zranitelnostem a metodám, které mohou vést k jejich kompromitaci.

Cílem projektu je vytvořit aplikaci schopnou simulovat útoky na hashovaná hesla a vyhodnocovat jejich úspěšnost vzhledem k použité metodě ochrany. Projekt kombinuje teoretickou analýzu bezpečného ukládání hesel s praktickou implementací útočných technik.

3. Cíle projektu

Hlavním cílem projektu je vytvořit nástroj, který dokáže simulovat různé typy útoků na hashovaná hesla a následně vyhodnotit, jak jsou tato hesla odolná vůči prolomení.

V rámci projektu budou implementovány tři základní metody útoků. Slovníkový útok, který využívá předpřipravené seznamy běžně používaných hesel. Útok hrubou silou, který systematicky zkouší všechny možné kombinace znaků. A zjednodušená implementace rainbow tables, tedy předpočítaných tabulek hashů, které umožňují rychlejší prolomení na úkor velikosti tabulek.

Kromě samotných útoků se projekt zaměří také na porovnání různých hashovacích funkcí z hlediska jejich odolnosti. Součástí bude i vyhodnocení toho, jak doba prolomení hesla závisí na jeho složitosti, tedy na délce, použitých znacích a mechanismech a celkové entropii.

Vedle těchto hlavních cílů bychom rádi vytvořili i uživatelsky přívětivé rozhraní pro snadné testování, doplněné o vizualizaci výsledků a statistik. Projekt by měl také prakticky demonstrovat, proč je důležité používat solení a moderní hashovací funkce.

4. Teoretická část

4.1. Bezpečné ukládání hesel

Hesla nesmí být nikdy ukládána v čistém textu, protože v případě kompromitace databáze by útočník okamžitě získal přístup k uživatelským účtům. Podle doporučení OWASP [1] je nutné používat jednosměrné hashovací funkce, doplněné o další ochranné mechanismy.

Základní principy bezpečného ukládání hesel zahrnují

- hashování, tedy jednosměrnou transformaci hesla
- solení, což znamená přidání náhodných dat k heslu před hashováním
- použití výpočetně náročných a pomalých hashovacích funkcí, které zpomalují útoky

4.2. Hashovací funkce

Hashovací funkce převádějí vstupní data na pevně dlouhý řetězec. Pro ukládání hesel je zásadní, aby byly odolné vůči pokusům o zpětný výpočet a zároveň dostatečně pomalé.

Funkce jako MD5 a SHA-256 jsou sice kryptografické hashovací funkce, ale jsou velmi rychlé, což je činí nevhodnými pro ukládání hesel [4]. Útočníci mohou díky GPU akceleraci testovat obrovské množství kombinací za krátký čas.

Bcrypt byl navržen přímo pro hashování hesel [2]. Obsahuje integrované solení a umožňuje nastavit tzv. cost faktor, který určuje výpočetní náročnost. Díky tomu je odolnější vůči moderním útokům a lépe se přizpůsobuje rostoucímu výkonu hardware [5].

4.3. Solení hesel

Solení spočívá v přidání unikátní náhodné hodnoty ke každému heslu před jeho hashováním. Tím se zajišťuje, že i stejná hesla mají odlišné hashe.

Hlavní výhodou solení je ochrana proti předpočítaným útokům, zejména rainbow tables. Bez soli by bylo možné použít již existující databáze hashů a výrazně urychlit prolomení hesel [1].

4.4. Metody útoků na hesla

Existuje několik základních metod útoků na hesla, které se liší svou efektivitou a náročností.

Slovníkový útok využívá seznamy běžných hesel a jejich variant. Je velmi efektivní proti slabým heslům a může prolomit přibližně 30 % hesel [3].

Útok hrubou silou systematicky zkouší všechny možné kombinace znaků. Je univerzální, ale jeho časová náročnost roste exponenciálně s délkou hesla. Pro heslo délky n ze znakové sady o velikosti k je potřeba až k^n pokusů [4].

Rainbow tables představují předpočítané tabulky hashů, které umožňují rychlé vyhledání hesel bez nutnosti opakovaného hashování. Jejich nevýhodou je vysoká náročnost na úložiště a neefektivita při použití solení [1].

4.5. Složitost hesel a entropie

Bezpečnost hesla lze vyjádřit pomocí entropie, která udává množství informace v hesle. Pro heslo délky n ze znakové sady o velikosti k platí:

$$E = \log_2(k^n)$$

Například heslo o délce 8 znaků

- pouze malá písmena (26 znaků) má entropii přibližně 37,6 bitů
- alfanumerické znaky a symboly (~94 znaků) mají entropii přibližně 52,4 bitů

Vyšší entropie znamená vyšší odolnost vůči útokům hrubou silou [4].

4.6. Rizika a jejich mitigace

Bezpečnost hesel je ovlivněna jak kvalitou hesel, tak způsobem jejich ukládání. Nesprávným nakládáním s hesly vzniká několik zásadních bezpečnostních rizik [1][5]. Mezi hlavní rizika patří krátká hesla, absence solení, použití nevhodných hashovacích algoritmů.

Tato rizika lze zmírnit kombinací následujících opatření

- zavedení pravidel pro silná hesla (zejména délka, pak kombinace znaků)
- použití unikátní soli pro každé heslo
- využití moderních hashovacích funkcí (např. bcrypt)
- omezení počtu pokusů o přihlášení a detekce útoků
- zákaz běžných hesel a edukace uživatelů
- případné využití vícefaktorové autentizace

4.7. Shrnutí

Bezpečné ukládání hesel vyžaduje kombinaci více přístupů. Samotné hashování nestačí, klíčovou roli hraje solení, volba vhodného algoritmu a ochrana proti útokům. Nejvyšší úroveň bezpečnosti lze dosáhnout kombinací silných hesel, pomalých hashovacích funkcí a vhodně navržených ochranných mechanismů.

5. Aktuální stav a návrh dalšího postupu

5.1. Aktuální stav projektu

Projekt se aktuálně nachází ve fázi návrhu a přípravy implementace. Byla provedena analýza zadání a rešerše zaměřená na bezpečné ukládání hesel, vlastnosti hashovacích funkcí a principy útoků na hesla. Na základě této analýzy byly definovány hlavní funkční požadavky a architektura řešení.

5.2. Návrh dalšího postupu

Jako implementační jazyk byl zvolen Python, a to především kvůli jeho jednoduchosti, dostupnosti knihoven pro hashovací funkce a rychlému vývoji. Byla navržena struktura aplikace, která umožní oddělit jednotlivé části systému a usnadní testování i následné vyhodnocení výsledků.

Aplikace bude rozdělena do několika základních modulů

- **hashers** – implementace hashovacích funkcí (MD5, SHA-256, bcrypt) a solení
- **attacks** – implementace útoků
- **rainbow** – zjednodušená implementace rainbow tables
- **database** – načítání a správa databáze hashovaných hesel
- **analyzer** – vyhodnocení výsledků a měření efektivity

Toto rozdělení umožňuje jednotlivé části vyvíjet nezávisle a zároveň je snadno kombinovat při testování.

5.2.1 Modul pro hashování

Modul pro hashování zajišťuje práci s různými hashovacími funkcemi (MD5, SHA-256, bcrypt) pomocí jednotného rozhraní. Pro MD5 a SHA-256 bude využita knihovna hashlib, pro bcrypt knihovna bcrypt.

Součástí modulu je také podpora solení hesel, které zvyšuje jejich odolnost vůči útokům. Modul umožňuje vytvářet hash ze zadaného hesla a ověřovat jeho správnost.

5.2.2. Slovníkový útok

Slovníkový útok bude pracovat se seznamem kandidátních hesel uložených ve slovníku. Pro každý hash v databázi bude postupně testovat jednotlivá hesla, aplikovat odpovídající hashovací funkci a porovnávat výsledek. Tento přístup je efektivní zejména pro slabá a běžně používaná hesla.

5.2.3. Útok hrubou silou

Útok hrubou silou bude generovat všechny možné kombinace znaků do zadané délky. Výhodou je jeho univerzálnost, protože nevyžaduje žádné předchozí znalosti o hesle. Nevýhodou je vysoká časová náročnost, která rychle roste s délkou a složitostí hesla.

5.2.4. Útok pomocí rainbow tables

Rainbow tables budou implementovány v zjednodušené podobě jako předpočítané řetězce hashů a redukčních funkcí. Tento přístup umožní urychlit útoky na nesolená hesla, protože není nutné opakovaně počítat hash pro každé heslo zvlášť.

5.2.5. Testovací databáze hashů

Pro testování budou vytvořeny databáze hashovaných hesel s různou úrovní složitosti. Budou zahrnovat jednoduchá hesla, běžná slovníková hesla i složitější kombinace znaků. Zároveň budou použity různé slovníky pro simulaci realistických útoků.

5.3. Plán měření a vyhodnocení

Cílem je objektivně vyhodnotit efektivitu útoků a odolnost hashovacích funkcí pomocí měřitelných metrik a kontrolovaných testů, jak je běžné v bezpečnostních studiích [3].

5.3.1. Měření metrik

Pro vyhodnocení budou sledovány následující klíčové metriky. Především doba prolomení hesla, tedy čas potřebný k nalezení původního hesla v závislosti na použitém hardware. Dále úspěšnost útoku, která udává poměr úspěšně prolomených hesel k celkovému počtu testovaných hesel na použitých datasetech a pravidlech. Sledována bude také výpočetní náročnost, tedy počet pokusů za sekundu a případně využití zdrojů. Na základě kombinace rychlosti a úspěšnosti bude vyhodnocena celková efektivita jednotlivých typů útoků.

5.3.2. Testovací data

Pro experimenty budou vytvořeny různé sady hesel, které budou reprezentovat odlišné úrovně bezpečnosti. Budou zahrnovat jednoduchá hesla jako běžná slovníková slova, středně složitá hesla obsahující kombinace znaků a čísel, komplexní hesla s velkými i malými písmeny, čísla a speciálními znaky a také hesla s různou délkou v rozmezí přibližně 4 až 12 znaků. Každé heslo bude hashováno pomocí vybraných hashovacích funkcí, a to jak bez soli, tak se solí, aby bylo možné analyzovat jejich vliv na bezpečnost.

5.3.3. Metodika vyhodnocení

Naměřená data budou zpracována a přehledně prezentována pomocí tabulek zachycujících čas, úspěšnost a počet pokusů. Výsledky budou doplněny o grafy znázorňující závislost doby prolomení na složitosti hesla a o vzájemné porovnání jednotlivých metod útoku a hashovacích funkcí.

Zvláštní důraz bude kladen na analýzu toho, jak délka a komplexita hesla ovlivňují dobu jeho prolomení. Zároveň budou porovnány rozdíly mezi hashováním se solí a bez soli a vyhodnocena efektivita jednotlivých útoků v závislosti na typu testovaného hesla.

5.3.4. Interpretace výsledků

Výsledky budou interpretovány s cílem odpovědět na následující otázky

- Která metoda útoku je nejefektivnější pro daný typ hesla?
- Jak výrazně zvyšuje bezpečnost použití soli?
- Jaký vliv má volba hashovací funkce na odolnost systému?

Na základě těchto zjištění bude formulováno doporučení pro bezpečné ukládání hesel a návrh případných vylepšení implementovaného nástroje.

6. Představení autorů

Zdeněk Ondra se věnuje především návrhu architektury aplikace a implementaci jednotlivých útoků. Současně se podílí na návrhu struktury projektu a integraci jednotlivých modulů do funkčního celku.

Lukáš Makovička se soustředí na práci s hashovacími funkcemi, jejich porovnání a zpracování testovacích dat. Dále se podílí na návrhu způsobu ukládání hashů a implementaci podpory solení.

Jiří Pokluda má na starosti vyhodnocení výsledků, návrh metrik a analýzu bezpečnosti hesel. Zároveň se věnuje interpretaci naměřených dat a jejich prezentaci ve formě přehledných výstupů a podílí se na implementaci.

Na teoretické části a finální podobě projektu se podílejí všichni autoři společně.

7. Závěr

Tato studie se zaměřuje na problematiku bezpečnosti hesel a jejich odolnosti vůči různým typům útoků. Na základě teoretické analýzy a návrhu implementace jsou definovány klíčové metody útoků, konkrétně slovníkový útok, útok hrubou silou a rainbow tables, spolu s porovnáním vybraných hashovacích funkcí.

Navržený plán měření a vyhodnocení umožňuje systematicky analyzovat efektivitu jednotlivých útoků pomocí definovaných metrik, jako je doba prolomení hesla, úspěšnost útoku a výpočetní náročnost. Výsledky budou interpretovány s cílem určit, která metoda útoku je nejefektivnější pro různé typy hesel, jaký vliv má použití soli na jejich bezpečnost a jak volba hashovací funkce ovlivňuje celkovou odolnost systému.

Na základě těchto zjištění budou formulována doporučení pro bezpečné ukládání hesel, zejména s důrazem na použití vhodných hashovacích funkcí, solení a dostatečné složitosti hesel. Současně budou identifikovány možné směry dalšího rozvoje projektu a návrhy na vylepšení implementovaného nástroje.

Projekt se aktuálně nachází ve fázi návrhu a postupné implementace jednotlivých modulů. V následujících krocích dojde k dokončení implementace, provedení experimentů a vyhodnocení získaných dat, což umožní ověřit stanovené předpoklady a dosažení vytyčených cílů.

8. Literatura

- [1] OWASP Foundation. *Password Storage Cheat Sheet*. Dostupné z: [https://cheatsheetseries.owasp.org/cheatsheets/Password Storage Cheat Sheet.html](https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html)
- [2] PROVOS, Niels; MAZIÈRES, David. *A Future-Adaptable Password Scheme (bcrypt)*. 1999. Dostupné z: <https://www.usenix.org/legacy/events/usenix99/provos/provos.pdf>
- [3] BONNEAU, Joseph. *The science of guessing: analyzing an anonymized corpus of 70 million passwords*. IEEE Symposium on Security and Privacy, 2012.
- [4] STALLINGS, William. *Cryptography and Network Security: Principles and Practice*. 7th ed. Pearson, 2017. ISBN 978-0134444284.
- [5] NIST. *Digital Identity Guidelines – Authentication and Lifecycle Management (SP 800-63B)*. Dostupné z: <https://pages.nist.gov/800-63-3/sp800-63b.html>